



Functional Testing of Security in Industrial Gateways under the New Machinery Regulation

Bachelor's Thesis T3_3300

Degree Programme Electrical Engineering

Field of Study Automation

Duale Hochschule Baden-Württemberg Ravensburg, Campus Friedrichshafen

by

Nathalie Nuber

Date of Submission:	August 10, 2026
Timeframe:	July 06, 2026 - August 10, 2026
Matriculation Number:	2257314
Course:	TEA 23
Dual Partner:	ifm ecomatic GmbH, Kressbronn a.B.
Supervisor:	M. Eng. Till Monzel
Reviewer:	M. Sc. Andreas Lau

Confidentiality Clause

The contents of this thesis may not be made available, either as a whole or in excerpts, to persons outside the examination and evaluation process, unless explicitly authorized by the Dual Partner. [End of restriction period: DD.MM.YYYY]

Kressbronn a.B., August 10, 2026

Nathalie Nuber

Nathalie Nuber

Declaration of Authorship

I hereby declare that I have authored this thesis independently, that I have not used other than the declared sources and resources, and that this thesis has not been submitted for any other examination with identical or comparable content, nor has it been published so far.

Kressbronn a.B., August 10, 2026

Nathalie Nuber

Nathalie Nuber

Abstract

English translation of the „Kurzfassung“.

Kurzfassung

Problemstellung

Ziel der Arbeit

Vorgehen und angewandte Methoden

Konkrete Ergebnisse der Arbeit, am besten mit quantitativen Angaben

200 bis 300 Wörter und beinhaltet die Fragestellung der Arbeit, die methodische Vorgehensweise sowie die Hauptergebnisse der Arbeit

Contents

1. Introduction	1
2. Fundamentals	4
2.1. Industrial Gateways in IT/OT Environments	4
2.1.1. Fundamentals of Industrial Gateways	4
2.1.2. IT/OT Interfaces	5
2.1.3. Attack Surface and Asset Identification	7
2.2. Regulatory and Standardization Framework	8
2.2.1. Regulation (EU) 2023/1230	8
2.2.2. prEN 50742	10
2.2.3. EN IEC 62443 Series	11
2.3. Cybersecurity Fundamentals	14
2.3.1. Security Goals	14
2.3.2. Threats, Vulnerabilities and Attack Vectors	15
2.4. Risk-Based Security Engineering	17
2.4.1. Threat Analysis and Risk Assessment (TARA)	17
2.4.2. STRIDE Methodology	18
2.4.3. Risk Evaluation	19
2.4.4. Risk Treatment Strategies	20
2.5. Security Testing Approaches	22
2.5.1. Testing Methodologies	22
2.5.2. Static and Dynamic Analysis	23
2.5.3. Vulnerability Assessment, Robustness, and Penetration Testing . .	24
3. Methodology	26
3.1. Derivation of Security Requirements	26
3.2. Functional Security Testing Framework Architecture	30
3.2.1. Scope and Boundaries	30
3.2.2. Traceability Model	30
3.2.3. Test Case Taxonomy	30
3.2.4. Verification Lifecycle and Governance	30

3.3. Evaluation Metrics and Assessment Scheme	30
3.3.1. Verdict Scheme	30
3.3.2. Regulatory Coverage Metric	30
4. Implementation, Results, and Evaluation	34
4.1. Testbed Setup and Target Specification	34
4.1.1. Test Object	34
4.1.2. Test Setup	36
4.1.3. Toolchain Integration	36
4.2. Application of the Testing Methodology	36
4.2.1. Authentication Tests	36
4.2.2. Authorization Tests	36
4.2.3. Configuration Tests	36
4.2.4. Firmware and Update Protection Tests	36
4.2.5. Logging and Traceability Tests	36
4.2.6. Communication Security Tests	36
4.3. Empirical Results and Compliance Evaluation	36
4.3.1. Test Results Overview	36
4.3.2. Evaluation of Mitigation Effectiveness	36
4.3.3. MVO Compliance Verification	36
4.3.3.1. HTTP-Based IoTCore Web Interface	38
4.3.3.2. REST API	38
4.3.3.3. Firmware Update Mechanism	39
4.3.3.4. PROFINET Communication	39
4.3.3.5. PROFIsafe Communication	40
4.3.3.6. Persistent Storage	40
4.3.3.7. Debug Interface	40
4.3.3.8. Engineering Environment	41
5. Summary and Outlook	44
5.1. Summary of Findings	44
5.2. Future Work	44
Bibliography	45
List of Figures	49
List of Tables	50
A. Note on the Use of Artificial Intelligence	51

B. Detailed Requirement Derivation Matrices	52
B.1. Security Requirements Derived from Regulation (EU) 2023/1230	52
B.2. Mapping to prEN 50742	57
B.3. Mapping to IEC 62443-4-2	59

1. Introduction

security als konformitätsanforderungen

bedarfsecurity testing

Definition Cybersecurity

For the scope of this thesis, the first five activities are applied. [1, p.54]

Problem Identification and Motivation

The introduction of the EU Machinery Regulation (EU) 2023/1230 establishes cybersecurity as a mandatory element of product conformity and safety. Industrial gateways operating at IT/OT interfaces are increasingly exposed to cyber threats due to their role in connecting traditionally isolated operational environments with corporate and external networks.

While existing validation approaches are focused on functional behavior, performance, and reliability, they provide only limited support for systematically verifying security-related functions. Consequently, manufacturers lack a structured methodology that demonstrates compliance with cybersecurity requirements specified by the Machinery Regulation, prEN 50742, and IEC 62443.

The identified research problem is therefore the absence of a repeatable and standards-based methodology for functional security testing of industrial gateways.

Definition of Objectives

Based on the identified problem, the objective of this research is to develop a security testing framework that:

supports verification of security functions within industrial gateways, provides traceability between regulatory requirements and concrete test activities, incorporates requirements derived from the Machinery Regulation, prEN 50742, and IEC 62443, focuses on security-relevant IT/OT communication interfaces, enables reproducible testing during product development and validation, generates objective evidence for conformity assessment and technical documentation.

The framework shall specifically evaluate whether implemented security controls effectively mitigate identified threats affecting confidentiality, integrity, and availability.

Design and Development of the Artifact

The artifact developed in this thesis is a Security Test Framework for Industrial Gateways.

The framework is derived through a structured process:

Analysis of regulatory requirements from the Machinery Regulation. Mapping of these requirements to cybersecurity objectives defined in prEN 50742 and IEC 62443. Identification of gateway assets, attack surfaces, and relevant threat scenarios using TARA and STRIDE principles. Derivation of security requirements and corresponding security functions. Selection of suitable testing techniques, including: vulnerability assessment, authentication and authorization testing, interface security testing, robustness and fuzz testing, penetration-oriented functional testing. Development of a traceability matrix linking: regulatory requirement, threat, security control, test objective, test method.

The resulting framework defines both the required test cases and the testing methodology necessary to verify implemented security controls.

Demonstration

The developed framework is demonstrated using a representative industrial gateway operating at an IT/OT interface.

The selected gateway serves as a case study and is used to execute representative security test procedures against relevant communication interfaces and security mechanisms.

Examples include:

user authentication mechanisms, role-based access control functions, secure communication channels, configuration integrity protection, logging and audit functionality, resistance against malformed network traffic.

The demonstration shows how the framework can be applied within an industrial product development process and how compliance evidence can be generated.

Evaluation and Validation Strategy

The evaluation assesses whether the developed artifact achieves the defined research objectives.

Validation is performed through a case study-based evaluation on the selected industrial gateway. The framework is evaluated against three criteria:

Regulatory Coverage

Assessment of whether all relevant requirements from:

Regulation (EU) 2023/1230, prEN 50742, IEC 62443-4-2

are addressed by at least one test activity.

Functional Applicability

Assessment of whether the proposed tests can be executed in a realistic industrial development environment without negatively impacting normal validation processes.

Effectiveness of Security Verification

Assessment of whether the framework can provide measurable evidence regarding the correct implementation of security functions and the effectiveness of technical mitigation measures.

The evaluation results are used to identify strengths, limitations, and potential improvements of the framework.

Sicherheitsmaßnahmen dürfen die funktionale Sicherheit nicht beeinträchtigen. [2, p. 17]

2. Fundamentals

2.1. Industrial Gateways in IT/OT Environments

2.1.1. Fundamentals of Industrial Gateways

Industrial gateways represent crucial architectural components that bridge the gap between distinct network environments by integrating both hardware and software functionalities. Their primary objective is to enable seamless communication between heterogeneous systems operating on different communication protocols. To achieve this, a gateway intercepts incoming data packets from a source system, translates or encapsulates the payload into a compatible format, and routes it to the target system. During this conversion process, protocol-specific overhead that is incompatible with the destination network is stripped away, while necessary parameters required by the target protocol are dynamically appended [3, pp. 277].

A gateway can operate across all layers of the Open Systems Interconnection (OSI) reference model [4]. In the context of this thesis, industrial gateways specifically facilitate the transition between Information Technology (IT) networks, typically dominant in layers 4 to 7, and Operational Technology (OT) networks, which operate heavily within layers 1 to 3 [5]. Consequently, managing this transition requires the gateway to reconcile various domain-specific constraints. These include differing physical layer standards, addressing schemes, transmission speeds, and data formats [4]. To ensure efficient translation, the protocol implementation and mapping generally occur at the lowest common layer shared by the interconnecting systems. Depending on the specific OSI layer at which the gateway operates, its internal processing mechanism and performance characteristics vary significantly [6].

2.1.2. IT/OT Interfaces

The ongoing digitization and networking within industrial value chains necessitate an increasing integration of two domains: Information Technology (IT) and Operational Technology (OT). While IT systems are primarily designed for the electronic storage, calculation, and transport of data, OT comprises a combination of hardware and software components explicitly utilized to monitor and control the performance of physical devices, machines, plants, and infrastructures. Operating predominantly within manufacturing and industrial environments, OT relies heavily on Industrial Control Systems, such as Supervisory Control and Data Acquisition (SCADA) systems [7, p. 1]. Traditionally, OT environments were realized as isolated networks relying on proprietary technologies. However, in the context of modern industrial paradigms, they are increasingly penetrated by networked technologies [7, p. 1].

Typical representatives of the IT domain include business-oriented software applications such as Enterprise Resource Planning (ERP) or Customer Relationship Management (CRM) systems. Conversely, the OT domain encompasses physical components on the shop floor, such as machines, scales, scanners, and sensors, along with the integrated control software that orchestrates them, such as Manufacturing Execution Systems (MES) [8, p. 404].

To systematically structure industrial environments, the architectural composition of OT can be categorized into four fundamental elements or functional levels [9]:

1. **Process Level:** This level consists of physical sensors and actuators that interact directly with the physical environment to perform actual mechanical work
2. **Control Level:** This layer comprises Programmable Logic Controllers (PLCs) and automated controllers that execute the underlying process logic and regulate physical operations in real-time
3. **Supervisory/Operation Level:** This level involves Human-Machine Interfaces (HMIs) and SCADA systems, which allow human operators to monitor system states visually, analyze anomalies, and intervene manually when necessary
4. **Operation IT / Data Layer:** Within this domain, raw OT data is aggregated, processed, and structured to make it valuable and actionable for higher-level applications

The technological convergence of IT and OT yields substantial operational and economic advantages. These advantages include enhanced transparency through the real-time acquisition of process data, the implementation of predictive maintenance strategies, the enablement of remote operation and maintenance, and comprehensive data-driven process optimization. Despite these benefits, IT/OT convergence introduces significant challenges, primarily because both domains operate under fundamentally conflicting requirements and distinct paradigms. These differences manifest across various dimensions, particularly regarding security priorities, protocols, and lifecycle management [9].

Table 2.1.: Comparison of Core Characteristics and Requirements in IT and OT Environments [7, p. 1] [9]

Characteristic	Information Technology (IT)	Operational Technology (OT)
Primary Focus	Information processing and data flow	Monitoring and control of physical processes
Security Priorities	Confidentiality → Integrity → Availability	Availability → Integrity → Confidentiality
Core Security Objectives	Authentication, Non-repudiation	Real-time availability, Functional Safety
Protocol Examples	TCP/IP, HTTP(S), SQL	Modbus, Profinet
Update Cycles	Regular, frequent, and automated	Rare, conservative, and strictly validated

The attributes summarized in Table 2.1 highlight the fundamental misalignment between the two domains, which complicates seamless interface design. The most critical divergence lies within the prioritization of the CIA triad (Confidentiality, Integrity, and Availability). In IT paradigms, data confidentiality and robust authentication mechanisms occupy the highest priority to prevent unauthorized access to sensitive information. In contrast, OT environments prioritize maximum availability and deterministic real-time execution, as any latency or system interruption could lead to physical damage, production downtime, or severe safety hazards on the shop floor [7, p. 1] [9].

This divergence further dictates how software maintenance and network communication are handled. While IT infrastructures rely on frequent, rapid security patching and standard communication protocols (such as HTTP or SQL), OT infrastructures adopt a highly conservative update policy. Because OT systems require rigorous validation and recertification to guarantee absolute operational safety, patches are applied rarely and only during planned maintenance windows. Furthermore, the underlying network communica-

tion in OT utilizes deterministic, low-overhead protocols like Modbus or Profinet, which lack built-in security features such as encryption [9].

2.1.3. Attack Surface and Asset Identification

For a systematic assessment of Industrial Internet of Things components such as industrial gateways, a granular decomposition of the target architecture into hardware, software, and data assets throughout the entire product life cycle is required [10, pp. 1].

The hardware asset dimension comprises the physical enclosure. It may include tamper protection features, alongside the underlying printed circuit boards (PCB) and core microprocessors or microcontrollers. These processing units often embed specialized security mechanisms like Trusted Execution Environments, True Random Number Generators and cryptographic accelerators. Furthermore, hardware assets encompass volatile and non-volatile memory components such as SRAM and EEPROM structures, as well as removable storage like SD cards or USB sticks [10]. Dedicated secure cryptoprocessors, including Trusted Platform Modules and Secure Elements, are part of this domain, together with connectivity structures and various physical input and output elements [10, p. 3].

The software asset dimension is formed by the firmware providing low-level hardware access, the underlying operating system or real-time operating system, and software-based cryptographic libraries. It also contains integrated communication protocol stacks for local, internet, or automation environments, such as TCP/IP, PROFINET, or OPC UA, alongside local or remote smart services. At the top of this stack sits the specific application logic responsible for tasks like data pre-processing or controlling actuators [10, p. 4].

All these components interact with various data assets that must be identified, which include the executable device code itself, configuration data, specific application data from sensor readings, diagnostic log data, and essential authentication data [10, p. 4]. The overall attack surface of the device is defined by the sum of all entry points and attack vectors that target these individual components throughout the life cycle phases [10, p. 1].

On the hardware level, chip-level vectors include the malicious insertion of hardware Trojans during design or production, physical data manipulation, and fault injection e.g.

via voltage glitching [10, p. 8]. On the PCB level, vectors focus on design cloning. Device-level physical vectors involve general sabotage. The software and application attack surface is primarily driven by vulnerabilities within the embedded firmware components, such as flaws in network stacks that allow remote code execution or denial of service. Application-layer entries include input validation flaws like SQL injection, typical web application vulnerabilities, data injection via spoofed sensor inputs [10, p. 8]. The network interface exposes the device to classic automation protocol weaknesses that lack native security controls, enabling man-in-the-middle and replay attacks, distributed denial of service (DDoS) attempts, and port scans [10, p. 9].

2.2. Regulatory and Standardization Framework

2.2.1. Regulation (EU) 2023/1230

With the publication of Regulation (EU) 2023/1230 (MVO) on June 29, 2023, in the Official Journal of the European Union, the European legislature initiated a fundamental paradigm shift regarding the product safety of machinery [11, p. 32]. The new regulation replaces the former Machinery Directive 2006/42/EC and becomes mandatory following a transition period starting January 20, 2027 [12, p. 38].

The primary legal distinction lies in its regulatory form. While the previous directive was addressed strictly to EU member states, requiring transposition into national law, a regulation applies directly to all economic operators, including manufacturers, importers, and distributors [11, p. 32] [12, p. 15]. This creates a standardized, uniform legal framework across the Union without national leeway for interpretation [12, p. 38]. Furthermore, the regulation introduces legally binding definitions for fundamental concepts such as “substantial modification”, formally clarifying when an alteration to an existing machine turns an operator legally into a manufacturer subject to full conformity assessment procedures [12, p. 25].

A key driver for this overhaul was the identification of regulatory gaps within the previous directive regarding emerging digital technologies [12, p. 2]. Consequently, the Regulation incorporates mandatory requirements for cybersecurity and protection against malicious third parties into the framework of product safety for the first time [11, p. 33]. Under the Machinery Regulation, cybersecurity is explicitly treated as a prerequisite for machinery safety, demonstrating that the functional safety of modern machinery can no longer be

evaluated independently of its cybersecurity [13].

This digitalization shift is also reflected in structural updates across the regulation's annexes. Most notably, the explicit list of safety components in Annex II now formally includes standalone software that fulfills safety functions, establishing that non-tangible, digital components are subject to the same strict conformity requirements as physical safety hardware [12, p. 42 f]. Additionally, in line with modern operational practices, manufacturers are now explicitly permitted to provide instructions for use in a digital format, provided that specific access, availability, and preservation requirements are met [12, p. 19].

Specific requirements apply to the components under Regulation (EU) 2023/1230 [12, pp. 44]. Annex III, Section 1.1.9 formulates explicit provisions regarding protection against corruption:

- The connection of any external device to the machine must not lead to a hazardous situation through any function of the connected device or via a remote access device [12, p. 48]
- Hardware components transmitting signals or data relevant to safety-related software must be adequately protected against accidental or intentional corruption
- Software and data essential for compliance with safety requirements must be identified as such and adequately protected against corruption
- The machine must collect evidence of legitimate or illegitimate interventions in the relevant hardware, software, or its configuration [12, p. 49]

Complementarily, Annex III, Section 1.2.1 addresses the safety and reliability of control systems, requiring them to be designed to withstand reasonably foreseeable malicious attempts by third parties that could lead to hazardous situations. A failure or disruption in data transmission must not cause a hazardous situation [12, p. 49].

Furthermore, Article 10(2) [12, p. 18] and Annex IV Part A [12, p. 83 f] obligate manufacturers to maintain comprehensive technical documentation. This documentation must include the risk assessment, descriptions of implemented protective measures, as well as test reports and trial results proving actual conformity with safety requirements [12, p. 83]. Upon a reasoned request from competent national authorities, access to the source code or programming logic of safety-related software must also be provided [12, p.

84].

2.2.2. prEN 50742

While the new MVO defines the overarching regulatory safety objectives regarding cybersecurity, the harmonized standard draft prEN 50742 (published in Germany as DIN EN 50742 / VDE 0113-742) provides the specific technical guidance for engineering and implementation. The standard acts as a bridge between regulatory compliance and practical machine design, with its primary focus on fulfilling the essential health and safety requirements of the MVO, specifically Annex III, sections 1.1.9 (*Protection against corruption*) and 1.2.1 (*Safety and reliability of control systems*) [2, p. 70]. PrEN 50742 aims at protecting the machine's functional safety and control systems against digital and physical manipulation, ensuring that cyber threats cannot cause hazardous situations [2, p. 10]. A fundamental requirement of the standard is that any implemented cybersecurity measure must not under any circumstances compromise or degrade the functional safety of the machine, for instance by introducing impermissible latencies in safety-critical communication loops [2, p. 14].

To accommodate different organizational prerequisites and product architectures, the standard defines two distinct conformity paths for manufacturers [2, p. 15]. Approach A represents a standalone, machine-specific methodology directly linked to classical safety risk assessments according to EN ISO 12100 [2, p. 16]. Under Approach A, the required strength of countermeasures is determined by calculating the Safety Related Security Level (SRSL 0 to 3), which is derived from the attack potential combined with the severity of potential safety-related harm [2, pp. 19].

In contrast, Approach B is specifically designed for complex systems and components that are integrated into larger industrial communication networks. Instead of using the standalone SRSL framework, Approach B directly utilizes the established EN IEC 62443 series to define and verify technical security requirements [2, pp. 16, pp. 24]. Under this approach, the system as a whole must comply with EN IEC 62443-3-3, while individual machine components must meet the technical security requirements of EN IEC 62443-4-2 at a specified Capability Security Level (typically SL-C 1 or SL-C 2) [2, p. 24].

Despite their methodological differences, both paths share identical core objectives regarding the technical protection of interfaces and the verification of control system integrity [2, p. 15]. Depending on the determined security level (SRSL under Approach A or SL-C

under Approach B), both frameworks mandate equivalent critical mitigation measures. First, entities attempting to intervene must be authenticated, and logical access must be restricted through role-based authorization to prevent unauthorized physical or logical access [2, pp. 17, pp. 24]. Second, the integrity of safety-related application software (SRASW), embedded software (SRESW), and configuration data must be verified cryptographically (e.g., during secure boot or continuously during operation) [2, p. 17 f]. Furthermore, the integrity of exchanged information across network boundaries must be secured to prevent spoofing or tampering, which includes a strict validation of input data at external interfaces [2, p. 50]. Both approaches require the secure, tamper-resistant digital logging of all security-relevant interventions for a minimum of five years to ensure complete traceability [2, p. 19, S. 23]. Ultimately, prEN 50742 establishes that cybersecurity compliance cannot be achieved by design alone. All implemented technical countermeasures must be structurally verified. Under Approach B, this verification directly maps to the testing of security functions defined by the EN IEC 62443 sub-standards [2, p. 14].

2.2.3. EN IEC 62443 Series

Within the landscape of industrial cybersecurity, the international standard series IEC 62443 serves as the foundational framework for securing Industrial Automation and Control Systems [14, p. 13].

IEC 62443-3-3 delineates the system-level security requirements, thereby bridging the gap between high-level organizational policies and technical implementation [14, p. 15]. The primary objective of this standard is to safeguard the availability, integrity, and confidentiality of industrial environments through a structured, risk-based approach [14, p. 6].

To achieve this objective, the standard establishes seven core pillars, referred to as Foundational Requirements (FRs), which define the essential technical capabilities a system must possess:

- **FR 1: Identification and Authentication Control (IAC):** Ensures that all users, software processes, and devices are uniquely identified and authenticated before being granted access to the system [14, p. 29].
- **FR 2: Use Control (UC):** Monitors and restricts the privileges of authenticated

entities, ensuring they can only execute authorized actions in accordance with the principle of least privilege [14, p. 41].

- **FR 3: System Integrity (SI):** Protects the system, applications, and data from unauthorized or malicious modifications to guarantee the trustworthy operation of OT components [14, p. 50].
- **FR 4: Data Confidentiality (DC):** Safeguards sensitive information against unauthorized disclosure both at rest and in transit across communication channels [14, p. 57].
- **FR 5: Restricted Data Flow (RDF):** Segmentizes the industrial network into defined security zones and conduits, limiting data communication to the absolute necessary minimum to prevent lateral movement of threats [14, p. 61].
- **FR 6: Timely Response to Events (TRE):** Mandates continuous security monitoring, logging, and anomaly detection to facilitate rapid incident response and mitigation in the event of a breach [14, p. 65].
- **FR 7: Resource Availability (RA):** Ensures that the system remains operational and critical functions are maintained even when subjected to faults or Denial-of-Service attacks [14, p. 67].

The fulfillment of these foundational requirements is evaluated through a granular metric known as Security Levels (SL), which quantify the system's resilience against various adversary profiles [14, p. 16]. These levels scale from SL 1, representing protection against casual or coincidental violations, up to SL 4, which demands robust defenses against highly sophisticated, state-sponsored cyber threats utilizing significant resources [14, p. 26 f]. In the context of system validation, the standard further distinguishes between the targeted security posture (SL-Target), the innate technical capabilities of the integrated components (SL-Capability), and the actual security level realized during operation (SL-Achieved) [14, p. 26].

However, achieving and verifying system-level security requires not only technical features, but also a structured development process, based on the core principle that a secure product can only emerge from a secure development lifecycle [15, pection 4.2]. To address this, **IEC 62443-4-1** specifies the process-oriented requirements for a Secure Product Development Lifecycle (SDLC) [15, Chapter: Introduction]. The standard structures these lifecycle capabilities across eight core practice areas:

- **Practice 1: Security Management (SM):** Ensures that security activities are planned, documented, and governed throughout the entire product lifecycle [15, Chapter: Security Management].
- **Practice 2: Specification of Security Requirements (SR):** Defines functional and non-functional security requirements based on product intent and threat scenarios [15, Chapter: Specification of Security Requirements].
- **Practice 3: Secure by Design (SD):** Mandates secure architecture principles, defense-in-depth strategies, and threat modeling during system design [15, Chapter: Secure by Design].
- **Practice 4: Secure Implementation (SI):** Focuses on secure coding standards, code reviews, and avoiding known software vulnerabilities [15, Chapter: Secure Implementation].
- **Practice 5: Security Verification and Validation Testing (SV):** Requires systematic security testing, including dynamic analysis, interface testing, and fuzzing prior to release [15, Chapter: Security Verification and Validation Testing].
- **Practice 6: Management of Security-Related Issues (DM):** Establishes processes for tracking, analyzing, and resolving identified vulnerabilities or defects [15, Chapter: Management of Security-Related Issues].
- **Practice 7: Security Update Management (SUM):** Defines procedures for creating, testing, and distributing security patches to affected deployments [15, Chapter: Security Update Management].
- **Practice 8: Security Guidelines (SG):** Demands comprehensive documentation to enable end users to securely configure, deploy, and operate the component [15, Chapter: Security Guidelines].

To measure the organizational rigor and repeatability of these eight practice areas, IEC 62443-4-1 introduces a metric scheme known as Maturity Levels (ML), scaling from ML 1 to ML 4. While ML 1 describes informal and unmanaged practices, ML 2 signifies adherence to documented processes. Progression to ML 3 requires organization-wide implementation and verification, whereas ML 4 mandates continuous metrics-based optimization of all lifecycle practices [15, section 4.2].

Building upon these lifecycle practice, **IEC 62443-4-2** shifts the focus to the individual technical building blocks, specifying the technical security requirements for IACS components [16, p. 18]. The primary objective of this standard is to ensure that the components integrated into an industrial system inherently possess the necessary technical capabilities to support the overarching system-level Security Levels (SL). To achieve this, the standard maps the seven Foundational Requirements (FRs) defined in the system-level framework directly onto four distinct component types: software applications, embedded devices, host devices, and network components [16, p. 17].

Analogous to the system-level standard, the concrete technical specifications within IEC 62443-4-2 are structured as Component Security Requirements (CRs) and further refined by Requirement Enhancements (REs)[16, pp. 32]. These CRs and REs are directly derived from the seven FRs, acting as the granular technical criteria that a component must satisfy to achieve a specific Component Security Level Capability (SL-C) [16, pp. 31].

For instance, while a system requires restricted data flow under FR 5, IEC 62443-4-2 translates this into explicit component capabilities, such as the network component's ability to enforce logical isolation, manage access control lists, and securely route or filter traffic at the physical IT/OT interface [16, pp. 61].

2.3. Cybersecurity Fundamentals

2.3.1. Security Goals

Within the domain of digital information security, the systemic alignment of cybersecurity strategies is traditionally anchored within a foundational guiding framework known as the *CIA (Confidentiality-Integrity-Availability) triad* [17] [18, p. 1]. This paradigm conceptualizes the three primary objectives required to establish a security posture and protect information assets against digital threats [19, p. 5]. To evaluate and mitigate risks effectively, these three distinct dimensions form the theoretical baseline [18, p. 24]:

- **Confidentiality:** Focuses on ensuring that sensitive data and information are strictly protected from unauthorized access or disclosure to unintended individuals, entities, and processes [19, p. 4] [18, p. 3]. In the specific context of IACS, the maintenance of authorized restrictions on access becomes paramount to secure

proprietary information, data configurations, and core operational parameters from illicit exposure [14, p. 23].

- **Integrity:** Revolves around the complete assurance that information and system components remain accurate, reliable, and trustworthy throughout their entire life-cycle [19, p. 4] [18, p. 3]. This objective actively safeguards digital assets against accidental or unauthorized modifications, deletions, and fabrications, which prevents erroneous decision-making or potential operational harm caused by altered data [19, pp. 4].
- **Availability:** Guarantees that essential services, computing systems, and communication interfaces remain continuously accessible and operational for authorized users precisely when needed [19, pp. 4] [18, p. 3]. This dimension dictates the overall resilience of the architecture against malicious disruptions, ensuring that operations can be sustained or recovered quickly to maintain customer trust and minimize financial losses [19, p. 5].

In practical deployment, these three primary security goals do not operate in isolation but exhibit a complex dynamic where they concurrently work together and against each other, frequently necessitating deliberate design trade-offs to balance conflicting requirements. While this triad establishes an essential baseline for data protection, modern distributed network environments demand explicit extensions to the classical CIA framework to address sophisticated threat vectors comprehensively. Possible additions include the goals of authenticity, and usefulness. Authenticity focuses on verifying that the transmitted information or system state genuinely is what it claims to be and incontrovertibly originates from the expected, legitimate source. Utility demands that data remains in a structurally usable, meaningful, and actionable form rather than merely being technically accessible to the organization [17] [20, pp. 102].

2.3.2. Threats, Vulnerabilities and Attack Vectors

A **threat** constitutes a circumstance, an event, or a various sequence of events capable of adversely affecting or compromising operations, including an organization's mission, functions, reputation, or standing. Furthermore, threats can directly target physical facilities, assets, automation and control systems, or individuals. These adverse impacts are typically realized through specific malicious actions, such as unauthorized access to data, its destruction, unauthorized disclosure, data alteration, or denial-of-service attacks

[14, p. 23].

A **vulnerability** represents a flaw in a system's design, implementation, or operation that can be exploited to corrupt system integrity [2, p. 12]. Although vulnerabilities are categorized into distinct types, the exact probability of their malicious exploitation cannot be predicted. Crucially, vulnerabilities do not create new physical hazards on their own. However, their exploitation can compromise integrated protective measures, which necessitates a formal threat assessment [2, p. 9]. To manage these latent risks, designers must adhere to a strict three-step mitigation hierarchy. First, present vulnerabilities that could cause hazardous situations must be eliminated entirely. Second, if complete elimination is technically unfeasible, the designer must actively mitigate the identified weakness. Finally, for any residual vulnerabilities, the information for use must provide the operator with detailed instructions for compensating countermeasures [2, p. 14].

An **attack vector** defines the specific method or means by which hackers gain unauthorized access to target systems in order to carry out a cyberattack. To ensure that no potential attack vectors are overlooked during the architectural analysis, a thorough, granular itemization of all hardware components, software components, and data types is required [10, p. 2] [10, p. 11]. Together, an organization's active attack vectors and its technical vulnerabilities constitute its total attack surface. In modern connected environments, this attack surface has continuously increased, exposing industrial assets to various common types of attack vectors utilized by adversaries, including:

- Third-party and supply chain compromises
- Denial-of-Service (DoS) attacks
- Compromised credentials
- Insider threats
- Exploitation of unpatched software or hardware vulnerabilities
- Injection and execution of malware
- Physical attacks on the infrastructure

Ultimately, the successful exploitation of these vectors allows attack actors to disable or destroy critical operational assets, which subsequently leads to significant business and

economic disruptions [21].

2.4. Risk-Based Security Engineering

2.4.1. Threat Analysis and Risk Assessment (TARA)

Threat Analysis and Risk Assessment (TARA) serves as a systematic methodology in cybersecurity to identify potential threats, assess associated risks, and formulate countermeasures to mitigate them to an acceptable level [20, p. 37]. Rather than relying on guesswork, TARA functions as a central tool to methodically derive concrete Cybersecurity Goals [22]. As part of overall risk management, it plays a critical role in ensuring regulatory compliance and producing secure products. The process is universally applicable across domains. However, conducting a TARA requires deep knowledge of the target system combined with specialized cybersecurity expertise. While it uncovers vulnerabilities and weaknesses, a TARA cannot provide definitive proof of security or guarantee an absolute defense [20, p. 38].

Throughout the system lifecycle, TARA is implemented iteratively across four distinct phases [20, p. 40]. An initial TARA occurs during early requirements engineering to evaluate baseline risks and define high-level security goals for the architecture. Before implementation begins, a detailed development TARA identifies component-level risks or adapts existing assessments for reused parts. During production, TARA evaluates manufacturing environments to prevent introducing vulnerabilities into the physical product. Finally, post-release TARAs are triggered by software updates or newly discovered vulnerabilities to continuously keep the risk profile up to date [20, p. 40].

The general workflow executes a sequential multi-step process from Item Definition and Asset Identification to Threat Analysis, Impact Rating, Feasibility Assessment, Risk Determination, and Risk Treatment. Within this context, a threat describes a potential event violating a cybersecurity property (Confidentiality, Integrity, or Availability), whereas a vulnerability represents a concrete weakness in design or implementation enabling that threat [22].

In practice, these workflow steps structure the primary operational domains of the assessment [20, p. 47, 49]. First, Asset Identification determines system assets, their required CIA properties, and prospective damage scenarios to establish an initial impact rating [20,

p. 46, 49][22]. Next, Threat Scenario Analysis defines potential attack vectors alongside specific attack paths, which detail the sequential steps an adversary must execute [20, p. 46][22]. Because no single threat source is comprehensive, team brainstorming supported by catalogs and the STRIDE methodology offers an efficient approach to threat identification [20, p. 135, 137]. Subsequently, Risk Evaluation combines the calculated impact ratings with attack feasibility metrics to derive overall risk levels [20, p. 47, 49][22]. Finally, the Risk Treatment Decision determines final Cybersecurity Controls, Goals, and Claims to effectively reduce identified risks [20, p. 37, 49][22].

2.4.2. STRIDE Methodology

The STRIDE methodology is a widely used threat modeling approach developed by Microsoft to address the fundamental question of what can go wrong in a system [23] [20, p. 143]. Rather than acting merely as a static threat categorization, STRIDE serves as a useful method for identifying specific threats based on potential attacker goals [20], [24].

The acronym STRIDE represents six distinct threat categories:

- **Spoofing:** The attacker pretends to be someone or something else. This involves illegally accessing and using another entity's authentication credentials, such as a username and password, or spoofing components and signals within embedded networks
- **Tampering:** Refers to the unauthorized, malicious modification of data or system functionalities. Examples include altering persistent data in a database, modifying firmware, or tampering with data in transit over an open network
- **Repudiation:** Occurs when an attacker performs a prohibited action in a system that lacks the ability to trace or audit operations, allowing the actor to deny performing the action without the system having proof otherwise
- **Information Disclosure:** Involves the exposure of data to unauthorized individuals. This includes data breaches, unauthorized file access, or reading data in transit across network connections
- **Denial of Service:** Threat actions aiming to disrupt system operation or deny access to legitimate users. Examples include making web servers temporarily unusable

or flooding bus systems with traffic to block valid messages

- **Elevation of Privilege:** An unprivileged attacker exploits vulnerabilities to gain higher access privileges than authorized. This allows the attacker to penetrate system defenses, access critical subsystems, and potentially compromise the entire system [23] [20, p. 144]

To systematically analyze these threats, Table 2.2 illustrates how each STRIDE category maps directly to the specific cybersecurity property it violates.

Table 2.2.: Mapping of STRIDE Threat Categories to Violated Cybersecurity Properties [20, p. 144] [24]

Threat Category	Cybersecurity Property Violated
Spoofing	Authenticity
Tampering	Integrity
Repudiation	Non-repudiation
Information Disclosure	Confidentiality
Denial of Service	Availability
Elevation of Privilege	Authorization

As shown in Table 2.2, the STRIDE threat categories represent the direct opposite of fundamental security objectives. By systematically evaluating system components against these paired relationships, threat lists can be derived to identify potential attacker goals and define required security controls [20, p. 144] [24].

2.4.3. Risk Evaluation

Risk evaluation serves as the central mechanism to determine and quantify the overall risk level associated with identified threat scenarios. Fundamentally, risk is defined as a combination of the potential impact resulting from an attack and its corresponding likelihood or feasibility [20, p. 196]. In literature, this relationship is frequently expressed through formal mathematical models. For instance, the risk level (R) can be determined by multiplying the likelihood (L) by the severity (S) of the impact [8, p. 648]:

$$R = L \cdot S \quad (2.1)$$

To systematically assess the impact parameter (I), criteria are established based on operational and safety domains. In safety-critical industrial environments, the impact rating

evaluates potential physical harm to humans across four distinct levels [20, p. 106]:

- **Severe (S3):** Fatal injuries or severe, life-threatening injuries where survival is uncertain
- **Major (S2):** Severe and life-threatening injuries where survival is probable
- **Moderate (S1):** Light to moderate physical injuries
- **Negligible (S0):** No physical injuries occur

Complementarily, the feasibility evaluation (F) determines the probability of occurrence by analyzing the technical effort and capabilities required for an adversary to execute specific attack paths [20, p. 135]. Attack feasibility is categorized into four distinct ratings [20, p. 151]:

- **High:** The attack path can be accomplished utilizing low effort
- **Medium:** The attack path can be accomplished utilizing medium effort
- **Low:** The attack path can be accomplished utilizing high effort
- **Very Low:** The attack path can be accomplished utilizing very high effort

For the final evaluation, assets, threat scenarios, attack paths, and resulting damage scenarios are combined into a structured matrix [20, p. 180]. By mapping the discrete impact ratings against the corresponding attack feasibility levels in a standardized risk matrix, the final numerical risk value is calculated. For instance, a damage scenario categorized with a *moderate* impact rating and a *high* attack feasibility yields a resulting risk value of three [20, p. 180]. Depending on specific institutional requirements and risk tolerance thresholds, individual organizations can make tailored adjustments to the underlying risk matrix structures [20, p. 182].

2.4.4. Risk Treatment Strategies

Following the evaluation of identified risks, appropriate risk treatment strategies must be defined. Generally, four primary strategies are available to address identified risks: risk

reduction, risk avoidance, risk sharing, and risk acceptance [20, pp. 200].

Risk Reduction: Risk reduction aims to decrease either the impact or the likelihood of a threat scenario. This is achieved by implementing technical countermeasures, also known as cybersecurity controls, which are typically derived from standardized or corporate catalogs [20, p. 200]. Table 2.3 summarizes standard technical mitigation techniques mapped to the corresponding STRIDE threat categories [24].

Table 2.3.: Technical Mitigation Techniques Mapped to STRIDE Threat Categories [24]

Threat Type	Mitigation Techniques
Spoofing Identity	Appropriate authentication, protection of secret data, avoiding secret storage
Tampering	Appropriate authorization, cryptographic hashes, MACs, digital signatures, tamper-resistant protocols
Repudiation	Digital signatures, timestamps, audit trails
Information Disclosure	Authorization, privacy-enhanced protocols, encryption, protection or non-storage of secrets
Denial of Service	Appropriate authentication and authorization, traffic filtering, throttling, Quality of Service
Elevation of Privilege	Execution under the principle of least privilege

Risk Avoidance: Risk avoidance involves modifying the fundamental design of the system component to eliminate the source of the risk entirely [20, p. 200].

Risk Sharing: Risk sharing distributes the risk among other stakeholders via contractual agreements or transfers it through insurance policies. In this case, a formal rationale in the form of a cybersecurity claim must be documented [20, p. 201].

Risk Acceptance: If the resulting risk level, impact, or attack feasibility is sufficiently low, accepting the risk represents a valid decision. Risk acceptance does not mean ignoring the threat. It strictly requires a documented rationale and cybersecurity claim to justify the acceptance [20, p. 201].

Once potential threats and corresponding countermeasures are established, a system threat profile can be derived into three distinct levels of mitigation [24]:

- **Non-mitigated threats:** Threats without countermeasures that expose fully exploitable vulnerabilities.
- **Partially mitigated threats:** Threats partially addressed by controls, resulting

in limited exploitability and impact.

- **Fully mitigated threats:** Threats with adequate countermeasures in place that leave no exposed vulnerabilities.

Even after implementing technical controls, a residual risk, may remain high. Residual risk represents the actual risk level present when an adversary attempts an attack path while active technical controls are in place [20, pp. 200].

2.5. Security Testing Approaches

Functional testing verifies whether a System Under Test (SUT) fulfills its specified primary functions. In contrast, non-functional testing evaluates aspects such as performance, usability, and security. Ensuring software security requires dedicated effort during development to identify vulnerabilities and implement effective protective measures. Security testing serves as a primary method to uncover these weaknesses [25, p. 291].

Software security testing activities are divided into functional security testing and security vulnerability testing. Functional security testing verifies the correct operation of planned security mechanisms, such as access control or authentication systems [26, p. 82] [27, p. 8]. Vulnerability testing aims to discover unaddressed design flaws and implementation bugs [27, p. 8]. A comprehensive testing strategy must combine both approaches to validate security features while simulating realistic attack scenarios [26, p. 81 f].

2.5.1. Testing Methodologies

Security testing approaches are categorized by the level of internal system knowledge available to the tester [25, p. 296]:

- **Black-Box Testing:** The tester has no knowledge of the internal system structure [25, p. 296]. Testing evaluates external software interfaces by executing the program with various inputs [26, p. 82]. Subcategories include fuzzy testing, which injects randomly generated data to infect or damage a system, and property-based testing, a model-based approach converting security properties into specifications via program slicing [25, p. 296].

- **White-Box Testing:** The evaluator has full access to the source code, logical paths, and architectural design. It enables manual code reviews, model-based techniques that check system models against security requirements, and fault injection to test interaction limits under malicious commands [25, p. 296].
- **Grey-Box Testing:** Tests are conducted with limited knowledge of the internal architecture by combining white-box and black-box techniques across multiple system layers [25, p. 296].

Techniques that cannot be strictly categorized into these paradigms include ethical hacking, penetration testing, and security regression testing. Penetration testing mimics actual attacker behavior to exploit system vulnerabilities. Ethical hacking expands this focus to evaluate weak points across the entire environment, including human operators and clients. Security regression testing specifically verifies that system upgrades or changes do not introduce new vulnerabilities [25, p. 296].

2.5.2. Static and Dynamic Analysis

Security analysis techniques are structured into static and dynamic execution paradigms. Static analysis inspects source code or control and data flow graphs using checklists without exercising the system with real runtime data [27, p. 35]. It detects errors early in development, but may miss runtime flaws [28, p. 1]. Conversely, dynamic analysis evaluates system behavior during runtime under different configurations and input data, comparing actual outputs against formal specifications [27, p. 35]. Dynamic testing provides real-world validation, it can disrupt system operations [28, p. 1].

Static Analysis Mechanisms: Static Application Security Testing (SAST) examines source code or binaries without execution [29]. As shown in Table 2.4, static detection primarily relies on code similarity-based and code pattern-based approaches [28, pp. 3]:

- **Code Similarity-Based Detection:** Identifies potential vulnerabilities by searching for known vulnerable code clones via string comparison, syntax analysis, or machine learning [28, p. 3]. Grammar-based techniques analyze grammatical code structures, whereas semantic-based techniques evaluate control and data flows to determine code meaning [28, pp. 4]. This approach requires less training data but cannot detect novel vulnerabilities [28, p. 8].

- **Code Pattern-Based Detection:** Utilizes machine learning and deep learning during a training and detection phase to recognize specific vulnerable code patterns [28, p. 5]. While dependent on data, it can discover new vulnerabilities [28, p. 8].

Combining both static approaches increases overall vulnerability detection effectiveness [28, p. 8].

Table 2.4.: Comparison of Static Analysis Detection Approaches [28, p. 3, 8]

Property	Code Similarity-Based	Code Pattern-Based
Operating Principle	Searches for similar code clones	Identifies specific code patterns
Techniques Used	String comparison, syntax and semantic analysis	Machine learning, deep learning
Advantages	Less dependent on training data	Capable of detecting new vulnerabilities
Disadvantages	Unable to detect new vulnerabilities	Highly dependent on training data

Dynamic Analysis Mechanisms: Dynamic Application Security Testing (DAST) evaluates running applications under real-world attack conditions [29]. Advanced dynamic penetration testing methodologies employ planning-based or reinforcement learning-based approaches to discover execution paths [28, p. 6]. Furthermore, Interactive Application Security Testing (IAST) combines static and dynamic feedback during runtime, while Software Composition Analysis (SCA) audits third-party dependencies for vulnerabilities and license compliance [29].

2.5.3. Vulnerability Assessment, Robustness, and Penetration Testing

A comprehensive testing framework requires evaluating feature functionality, performance, and robustness [27, p. 48]:

- **Vulnerability Scanning:** Automated tools scan hosts, open ports, and operating systems to match system configurations against databases of known vulnerabilities [30, p. 27].
- **Robustness Testing and Fuzzing:** Robustness measures a system's ability to operate correctly under exceptional inputs or environmental stress [27, p. 39]. Fuzzing

is an automated robustness testing technique that repeatedly injects invalid, random, or unexpected inputs into target interfaces to provoke data handling errors or crashes. Fuzzing varies by input generation: “dumb” fuzzing performs random mutations without input format knowledge, while “smart” fuzzing uses input models. Based on system access, white-box fuzzing utilizes program analysis, grey-box fuzzing uses lightweight instrumentation, and black-box fuzzing operates without internal knowledge [28, p. 8] [27, p. 29].

- **Penetration Testing:** Evaluators mimic real-world cyberattacks to identify exploitable vulnerability combinations [25, p. 296]. According to NIST SP 800-115, penetration testing follows four stages: *Planning*, *Discovery*, *Attack*, and *Reporting* [30, p. 37].
- **Fault Injection and Mutation Testing:** Fault injection evaluates interaction points by forcing the system to process malicious commands [25, p. 296]. Mutation testing evaluates test suite effectiveness by injecting single syntactic changes, such as variable renaming or operator replacements, to create faulty software versions. It relies on three core assumptions: competent programmers make small errors, selected mutation operators represent typical human errors, and a coupling effect allows simple mutations to uncover subtle bugs [27, p. 50].

3. Methodology

This chapter describes the methodological approach used to develop and evaluate the proposed security testing framework. Building upon the theoretical foundations presented in Chapter 2, the research follows the Design Science Research Methodology (DSRM) proposed by Peffers et al. DSRM provides a structured process for addressing practical problems through the design, development, demonstration, and evaluation of artifacts [1, p. 46]. The objective of this research is the development of a standards-based functional security testing framework for industrial gateways. The framework is intended to enable the traceable, repeatable, and systematic verification of security functions derived from the requirements of Regulation (EU) 2023/1230, prEN 50742, and the IEC 62443 series. Within the scope of this thesis, the activities of the DSRM process are mapped to the corresponding chapters. Problem identification and objective definition are presented in Chapter 1. The design and development phase is addressed in this chapter through the derivation of security requirements and the development of the proposed testing framework. The demonstration and evaluation phases are conducted in Chapter 4, where the framework is applied to an industrial gateway as a case study. The communication phase is represented by the documentation, discussion, and dissemination of the research results through this thesis.

3.1. Derivation of Security Requirements

The aim is to produce a structured, traceable set of product requirements for an industrial gateway at the IT/OT interface, grounded in the legal obligations of Regulation (EU) 2023/1230. The complete requirement catalogue, prEN 50742 mapping, and IEC 62443-4-2 mapping are documented in Appendix B.

The derivation follows a three-stage hierarchical chain:

1. **Regulation (EU) 2023/1230** defines legally binding protection objectives for

machinery, including explicit cybersecurity obligations.

2. **prEN 50742** operationalizes these objectives for connected machinery and links them to the IEC 62443 series.
3. **IEC 62443-4-2** specifies component-level technical security requirements (CRs, REs, EDRs) that can be verified by functional testing.

None of the three sources is independently sufficient. Regulation (EU) 2023/1230 defines mandatory objectives but not component-level technical specifications. IEC 62443-4-2 provides precise technical controls but does not by itself establish which are required for Machinery Regulation conformity. PrEN 50742 preserves legal traceability while introducing technically interpretable obligations that can be mapped to IEC 62443-4-2.

Regulation (EU) 2023/1230 establishes that machinery certified under a cybersecurity certification scheme pursuant to Regulation (EU) 2019/881 is presumed to comply with the essential health and safety requirements of Annex III insofar as these requirements are covered by the certification. The cybersecurity provisions explicitly addressed by this presumption are:

- **Section 1.1.9** (Protection against corruption): obligations concerning safety-relevant hardware interfaces, software and data protection, and evidence collection.
- **Section 1.2.1** (Safety and reliability of control systems): obligations concerning resilience against malicious third-party attempts and logging of safety-relevant interventions.

Each regulatory clause was decomposed analytically into candidate requirements. The decomposition applied the following four criteria:

1. **Traceability:** The requirement must trace directly to an explicit obligation in **Regulation (EU) 2023/1230**.
2. **Atomicity:** Each requirement must express exactly one verifiable technical property. Clauses combining multiple independent obligations were split into separate requirements.
3. **Verifiability:** The requirement must be testable in principle by a functional test or a clearly delimited technical assessment.

4. **Product relevance:** The requirement must describe a property of the gateway as a product, not an organizational, documentation, or purely functional-safety obligation.

Each candidate requirement was compared with **prEN 50742** to determine whether the draft standard provides a technically defensible interpretation for the machinery domain. Four mapping types were defined:

- **Direct:** clause-level match
- **Partial:** scope or trigger condition differs
- **Indirect:** related principle, no clause-level match
- **Not identified:** confirmed gap or conflict

Where **prEN 50742** provided clause-level support, the corresponding IEC 62443-4-2 CRs, REs, and EDRs were identified. One additional mapping type was introduced for IEC 62443-4-2: **No direct mapping** (no CR addresses the obligation).

Controls were selected only where the connection to the regulatory source could be substantiated through the derivation chain. The role of the Foundational Requirements (see Section 2.2.3) was classificatory. The selection of specific CRs was driven by the protection goals established in the earlier stages.

Confirmed normative gaps arise for two requirements within the scope of Sections 1.1.9 and 1.2.1. RQ-010 addresses resilience against malicious third-party attempts at a system level. IEC 62443-4-2 assigns such process-level obligations to IEC 62443-4-1, and no component-level CR provides a direct mapping. RQ-013 presents a confirmed conflict: the MVO requires logging of uploaded safety software versions, whereas prEN 50742 explicitly excludes binary software versions from the tracing log. These two gaps define the positions where the standard-based test approach must be supplemented by product-specific verification.

The detailed mapping tables are provided in Appendix B.2 (prEN 50742) and Appendix B.3 (IEC 62443-4-2).

The derivation produced 14 requirements (RQ-001 to RQ-014). Each requirement was classified by the security objective it primarily expresses, corresponding to the security

goals and Foundational Requirements introduced in Sections 2.3.1 and 2.2.3. Table 3.1 summarizes the resulting categories and the IEC 62443-4-2 coverage achieved.

Table 3.1.: Summary of Derived Security Requirement Categories

Category	FR	Req. IDs	IEC 62443-4-2 Coverage
Secure Communication	FR3	RQ-001	Partial
Data and Software Integrity	FR3	RQ-002, RQ-005	Direct (RQ-005); Partial (RQ-002)
Configuration Protection	FR1, FR2, FR7	RQ-004, RQ-006, RQ-007, RQ-011	Partial
Logging and Auditability	FR2, FR3	RQ-003, RQ-008, RQ-009, RQ-012, RQ-013	Direct (RQ-003, RQ-008, RQ-009, RQ-012); None (RQ-013)
Access Control	FR3, FR6	RQ-014	Partial
Availability / Resilience	-	RQ-010	None

Of the 14 requirements, 5 achieve a Direct IEC 62443-4-2 mapping, 7 achieve a Partial mapping, and 2 obtain no direct IEC 62443-4-2 counterpart. The complete requirement catalogue with source text, security objective, requirement type, and rationale is provided in Appendix B.1.

The derived requirement base defines the test scope of this thesis. Requirements with a Direct or Partial IEC 62443-4-2 mapping form the primary basis for functional test case design, since they correspond to established, technology-neutral component security capabilities. Partially mapped requirements require interpretive judgment when converted into executable test procedures.

Requirements classified as *No direct mapping* define the normative boundary of the standard-based approach. At these positions, the test methodology must incorporate product-specific verification procedures or explicitly document the remaining conformity gap.

The categorization in Table 3.1 structures the subsequent test case design. Each security function category is associated with a set of test strategies drawn from the testing approaches described in Section 2.5. Requirements within a category with identical IEC 62443-4-2 anchors share the same verification logic and can be addressed by a common test procedure.

3.2. Functional Security Testing Framework Architecture

3.2.1. Scope and Boundaries

This thesis is delimited to **Functional verification**, i.e., the testing of implemented security functions against the requirement baseline (Section 3.1), as opposed to **robustness testing** (fuzzing, penetration testing) at the gateway's IT/OT interfaces, as already distinguished in Section 2.5 and Section 2.5.3.

Within this scope, the framework verifies that the security functions and countermeasures mandated by RQ-001 to RQ-014 are actually implemented and operate as specified at the interfaces identified as gateway assets in Section 2.1.3. Fuzzing, penetration testing, and open-ended vulnerability scanning are explicitly out of scope, consistent with the exclusions already defined in Chapter 1. These techniques search for unknown weaknesses rather than verifying a specified, requirement-bound behavior, and therefore answer a different question than the one posed by this framework [27, p.8, pp. 29].

3.2.2. Traceability Model

3.2.3. Test Case Taxonomy

3.2.4. Verification Lifecycle and Governance

3.3. Evaluation Metrics and Assessment Scheme

3.3.1. Verdict Scheme

3.3.2. Regulatory Coverage Metric

Prüfverfahren: OWASP: - Logging Testing - Log Injection Testing - Log Integrity Verifi-

cation NIST SP 800-115: - Security Configuration Review - Audit Review - File Integrity Verification

Problem aktueller Methodiken: - klassischer Funktionale Ansatz (Black-Box-Ansatz): Prüft nur Soll-Verhalten, Keine Aussage über Angriffswiderstand > Für Nachweisführung regulatorischer Anforderungen allein nicht ausreichend - Security Verificaton nach IEC 62443: Abstrakt, liefert keine konkreten Testfälle > bietet aber Grundlage für die Ableitung systematischer Testfälle - Penetration Testing: Geringe Reproduzierbarkeit, Ergebnis abhängig vom Tester > Für die Maschinenverordnung liefern Penetration Tests starke Evidenz, ersetzen jedoch keine strukturierte Verifikationsmethodik. - Fuzz Testing: Erfordert spezialisiertes Testsetup, schwierige Ergebnisanalyse > geeignet für Prüfung robuster Kommunikation und Fehlerbehandlung nach IEC 62443 - Protocol Security Testing - OWASP IoT Security Testing Guide: nicht speziell für OT entwickelt - Risk-based Security Testing: Aufwendige Risikoanalyse notwendig

In the context of industrial gateways, which act as critical boundaries at the IT/OT interface, these devices are primarily evaluated under the stringent requirements for network components.

Funktionale Tests prüfen, ob das System tut, was es soll. Security Tests prüfen, ob das System auch das unterlässt, was es nicht tun darf.

Deswegen kombiniertes Testframework:

1. Risk Assessment / Threat Modelling 2. Ableitung von Security Requirements 3. Funktionale Security Tests 4. Protocol Security Tests 5. Fuzz Testing 6. Gezielte Penetration Tests 7. Compliance-Mapping auf EU-Maschinenverordnung und IEC 62443

Testframework 1. Requirement Analysis

2. Asset Identification

3. Threat Modeling (TARA + STRIDE)

4. Mapping to IEC 62443 Requirements

5. Definition of Security Test Objectives

6. Test Implementation

7. Result Evaluation

8. Compliance Evidence

Research of Test Methods

Spoofing -> Authentizität -> IEC 62443 FR1/FR2-> Authentication Testing Schutz vor unbefugtem Zugriff auf Sicherheitsfunktionen und Steuerungen (1.1.9, 1.2.1) Tampering -> Integrität -> IEC 62443 FR3 -> Integrity Testing Software, Daten und Kommunikationspfade müssen gegen absichtliche oder unbeabsichtigte Veränderung geschützt werden (1.1.9) Repudiation -> Nachvollziehbarkeit-> IEC 62443 FR6 -> Audit Logging Test Nachweis legitimer und illegitimer Eingriffe; Protokollierung von Änderungen (1.1.9) Information Disclosure-> Vertraulichkeit -> IEC 62443 FR4 -> Encryption Testing Schutz sicherheitsrelevanter Daten vor unbefugtem Zugriff Denial of Service -> Verfügbarkeit -> IEC 62443 FR7 -> Availability Testing Sicherheitsfunktionen müssen auch bei Störungen oder Angriffen wirksam bleiben (1.2.1) Elevation of Privilege-> Autorisierung -> IEC 62443 FR2 -> Privilege Escalation Testing Nur autorisierte Personen/Systeme dürfen sicherheitsrelevante Funktionen ändern oder ausführen

Spoofing (Identitätsdiebstahl) → Authentizität (IEC 62443 FR1) → Authentication Testing

Tampering (Manipulation) → Integrität (IEC 62443 FR3 / MaschVO Anhang III) → Integrity Testing

Repudiation (Abstreitbarkeit) → Non-repudiation (IEC 62443 FR6) → Audit & Logging Testing

Information Disclosure (Offenlegung) → Vertraulichkeit (IEC 62443 FR4) → Confidentiality Testing

Denial of Service (Dienstblockade) → Verfügbarkeit (IEC 62443 FR7) → DoS/ Robustness Testing

Elevation of Privilege (Rechteausweitung) → Autorisierung (IEC 62443 FR2) → Authorization Testing

Replay Testing → Replay Threats

Secure Update Testing → Firmware

Input Validation Testing → Manipulated Configurations

Fuzz Testing → Protocol Interfaces

Communication Security Testing → PROFINET/PROFIsafe/IoT

Secure Storage Testing → EEPROM/Remanent Data

The engineering environment represents an indirect attack surface. This includes GSDML files, parameter data, engineering tools and CRC generation tools used during commissioning and configuration. Manipulation of these artifacts may result in incorrect device configuration or unsafe system behaviour

Security Requirements for Industrial Gateways

Hier leitest du aus den Normen die tatsächlich testbaren Security-Funktionen ab.

Requirement Security Function Authentication Login Mechanismus Authorization Rollen- und Rechtekonzept Integrity Secure Boot Integrity Signed Firmware Confidentiality TLS Availability DoS Protection Logging Audit Trail

4. Implementation, Results, and Evaluation

4.1. Testbed Setup and Target Specification

4.1.1. Test Object

The test object used for the security assessment is the Safe Remote I/O (SRIO), a fieldbus-based safety gateway for industrial automation systems. The device enables the transmission of safety-related input and output data between field devices and a higher-level safety controller via PROFINET and PROFIsafe communication. The evaluated device was operated with firmware version on hardware revision. All tests described in this thesis were performed on a specific configuration.

Based on the asset classification introduced in Section 2.1.3, the SRIO consists of hardware, software, and data assets. The hardware assets include the communication module (COM), the safety CPU module (SCPU), non-volatile memory components, and the physical enclosure. Externally accessible hardware interfaces comprise the Ethernet port, power supply connectors, safe digital input and output interfaces, rotary switches, and status LEDs. Internal interfaces include the SysCom connection between the COM and SCPU modules, inter-processor communication channels, and JTAG debugging interfaces.

The software assets consist of the COM firmware, SCPU firmware, bootloader, and NetX90 firmware. In addition, the device provides an embedded IoTCore service, a PROFINET communication stack, a PROFIsafe implementation, and a firmware update mechanism. These software components provide network connectivity, device management, diagnostic functions, and safety-related communication services.

The data assets include network configuration parameters, PROFIsafe configuration data,

iPar parameters, firmware images, process data, diagnostic information, and device identity information such as serial number, hardware version, and software version. Configuration and safety-related parameters are stored in non-volatile memory and are therefore considered critical assets. From a security perspective, the primary interfaces are the HTTP-based IoTCore web interface, the associated REST API services, the PROFINET and PROFIsafe communication services, the DCP configuration functions, and the firmware update service. These interfaces represent the main externally reachable attack surface of the device and therefore form the focus of the security assessment presented in this thesis.

4.1.2. Test Setup

4.1.3. Toolchain Integration

4.2. Application of the Testing Methodology

4.2.1. Authentication Tests

4.2.2. Authorization Tests

4.2.3. Configuration Tests

4.2.4. Firmware and Update Protection Tests

4.2.5. Logging and Traceability Tests

4.2.6. Communication Security Tests

4.3. Empirical Results and Compliance Evaluation

4.3.1. Test Results Overview

4.3.2. Evaluation of Mitigation Effectiveness

4.3.3. MVO Compliance Verification

Vorhandene Security-Funktionen: nur HTTP-Verbindung, Firmware-Update-Geschützt, Read-only-IoT > nicht alles, Netztrennung Safety/Standardkommunikation, Fehler-und Ergebnisprotokollierung, Kommunikationsüberwachung, PROFIsafe Schutzmechanismen

FR	Name	Relevant Gateway Assets
FR1	Identification and Authentication Control (IAC)	IoT Core, Firmware Update
FR2	Use Control (UC)	IoT Core, Configuration functions
FR3	System Integrity (SI)	Firmware Update, PROFIsafe, Configuration
FR4	Data Confidentiality (DC)	HTTP Interface, Configuration data
FR5	Restricted Data Flow (RDF)	Ethernet, PROFINET, IoT Core
FR6	Timely Response to Events (TRE)	Error Log, Diagnostics
FR7	Resource Availability (RA)	Ethernet, PROFINET, DCP

Table 4.1.: Foundational Requirements and Relevant Gateway Assets

Mapping Attack Surface > Testverfahren Attack Surface Threat Test Method Web Interface Spoofing Authentication Test REST API Tampering API Security Test Modbus Interface Replay Protocol Test Firmware Update Tampering Integrity Test Ethernet Port DoS Robustness Test

STRIDE-Mapping auf IEC 62443 / MaschVO:

Spoofing (Identitätsdiebstahl) → Authentizität (IEC 62443 FR1)

Tampering (Manipulation) → Integrität (IEC 62443 FR3 / MaschVO Anhang III)

Repudiation (Abstreitbarkeit) → Non-repudiation (IEC 62443 FR6)

Information Disclosure (Offenlegung) → Vertraulichkeit (IEC 62443 FR4)

Denial of Service (Dienstblockade) → Verfügbarkeit (IEC 62443 FR7)

Elevation of Privilege (Rechtheausweitung) → Autorisierung (IEC 62443 FR2)

Beispiel 1: HTTP-based IoTCore / REST-API Interface Involved Assets: Configuration Data, Firmware, Device Identity Data.

Threat Identification (STRIDE):

Spoofing: Unauthenticated access using default/weak credentials.

Tampering: Request Manipulation (Parameter Tampering) to alter network/IP configurations without proper authorization.

Information Disclosure: Unencrypted transport of credentials or device identity data.

Denial of Service: HTTP/REST API flooding (Resource Exhaustion).

Elevation of Privilege: Broken Access Control (Bypassing authentication to reach administrative endpoints).

4.3.3.1. HTTP-Based IoTCore Web Interface

STRIDE Category	Identified Threat
Spoofing	Unauthorized Access
Spoofing	Session Spoofing
Tampering	Request Manipulation
Tampering	Configuration Manipulation
Repudiation	Missing Audit Trail
Information Disclosure	Disclosure of Device Information
Information Disclosure	Disclosure of Diagnostic Data
Denial of Service	HTTP Flooding
Denial of Service	Resource Exhaustion
Elevation of Privilege	Privilege Escalation

Table 4.2.: Threats identified for the IoTCore web interface

4.3.3.2. REST API

STRIDE Category	Identified Threat
Spoofing	Unauthorized API Access
Tampering	Parameter Manipulation
Tampering	API Request Manipulation
Repudiation	Missing Request Logging
Information Disclosure	Exposure of Device Information
Information Disclosure	Exposure of Log Data
Denial of Service	API Flooding
Elevation of Privilege	Access to Restricted Functions

Table 4.3.: Threats identified for the REST API

4.3.3.3. Firmware Update Mechanism

STRIDE Category	Identified Threat
Spoofing	Fake Update Source
Tampering	Modified Firmware
Tampering	Firmware Downgrade
Tampering	Corrupted Firmware Package
Repudiation	Missing Update Traceability
Information Disclosure	Firmware Extraction
Denial of Service	Interrupted Update Process
Denial of Service	Invalid Firmware Installation
Elevation of Privilege	Execution of Unauthorized Firmware

Table 4.4.: Threats identified for firmware updates

4.3.3.4. PROFINET Communication

STRIDE Category	Identified Threat
Spoofing	Device Spoofing
Spoofing	Faked PLC/F-Host
Tampering	Process Data Manipulation
Tampering	DCP Parameter Manipulation
Repudiation	Missing Configuration Traceability
Information Disclosure	Network Enumeration
Information Disclosure	Device Discovery
Denial of Service	Network Flooding
Denial of Service	Communication Disruption
Elevation of Privilege	Unauthorized Configuration Changes

Table 4.5.: Threats identified for PROFINET communication

4.3.3.5. PROFIsafe Communication

STRIDE Category	Identified Threat
Spoofing	Fake F-Host
Tampering	Safety Telegram Manipulation
Tampering	Safety Parameter Manipulation
Repudiation	Missing Safety Event Logging
Information Disclosure	Disclosure of Safety Parameters
Denial of Service	Communication Timeout Attack
Denial of Service	Message Flooding
Elevation of Privilege	Unauthorized Safety Functions

Table 4.6.: Threats identified for PROFIsafe communication

4.3.3.6. Persistent Storage

STRIDE Category	Identified Threat
Spoofing	Identity Data Manipulation
Tampering	Configuration Tampering
Tampering	Safety Parameter Tampering
Information Disclosure	Extraction of Stored Data
Denial of Service	Corrupted Configuration Data

Table 4.7.: Threats identified for persistent storage

4.3.3.7. Debug Interface

STRIDE Category	Identified Threat
Tampering	Firmware Modification
Tampering	Memory Manipulation
Information Disclosure	Firmware Extraction
Information Disclosure	Memory Dump
Denial of Service	Device Lockup
Elevation of Privilege	Debug-Based Privilege Escalation

Table 4.8.: Threats identified for the debug interface

4.3.3.8. Engineering Environment

STRIDE Category	Identified Threat
Spoofing	Malicious Engineering Station
Tampering	Manipulated GSDML File
Tampering	Manipulated Parameter Set
Tampering	Manipulated CRC Tool Output
Repudiation	Missing Change Tracking
Information Disclosure	Disclosure of Engineering Data
Denial of Service	Invalid Device Configuration
Elevation of Privilege	Unauthorized Engineering Changes

Table 4.9.: Threats identified for engineering assets

Threat Catalogue:

- Unauthorized access to the IoTCore web interface
- Authentication bypass
- Session hijacking
- Brute-force login attempts
- REST API request manipulation
- Unauthorized configuration changes
- Firmware manipulation
- Unauthorized firmware updates
- Firmware downgrade attacks
- Denial-of-Service against network services
- Ethernet packet manipulation
- PROFINET device spoofing

- Replay attacks on industrial communication
- Manipulation of safety-related parameters
- Unauthorized access to persistent configuration storage
- Disclosure of device identity information

Feld	Spalte	Beispiel-Inhalt	Threat ID	TH-FW-01	Asset ID	AST-02	Asset Name	SCPU Firmware	Description																											
		Firmware für sicherheitsgerichtete Funktionen (Safety-CPU).	Threat	Tampering (Manipulation)	Threat description	Ein Angreifer lädt eine präparierte Firmware über die REST-API/HTTP-Schnittstelle hoch, um Sicherheitsfunktionen zu deaktivieren.	Protection Goal	Integrity (IEC 62443-4-2 CR 3.4 - Software Integrity)	Attacker / Skill-Level	Network Attacker / High Skills	Rationale	Relevanz für MaschVO Anhang III: Manipulation führt zum Verlust der Funktionalen Sicherheit.	Exposure Level	High (Über IT/OT-Schnittstelle erreichbar)	Exploitability	High (Falls keine Signaturprüfung vorhanden ist)	Likelihood	b. mit. High	Impact	Critical (Gefahr von Personenschäden durch fehlerhafte Steuerung)	Risk (before)	HIGH / UNACCEPTABLE	Weakness	Fehlende Überprüfung der Integrität und Authentizität des Update-Images (CWE-345).	Mitigation	Implementierung einer Asymmetrischen Signaturprüfung (z. B. ECDSA/RSA) im Secure Bootloader vor dem Einspielen.	Risk strategy	Mitigate	Exploitability (after)	Low (Signatur kann ohne privaten Schlüssel nicht gefälscht werden)	Likelihood (after)	Low	Severity (after)	Critical (Schadenspotenzial im Erfolgsfall bleibt hoch, aber Ausführung unwahrscheinlich)	Risk after mit.	LOW / ACCEPTABLE

Beispiel 1: Unauthorised Access auf IoTCore Web Interface

Feld	Inhalt	Threat ID	T-001	Asset ID	A-001	Asset Name	Configuration Data	Description	Network and device configuration parameters	Threat	Unauthorized Access	Threat description	Attacker gains access to configuration functions without authorization	Protection Goal	Integrity, Confidentiality	Attacker / Skill-Level	Low	Rationale	Web interface reachable via Ethernet predefined likelihood	Medium	Exposure Level	High	Exploitability	Medium	Likelihood	based on Matrix	High	Impact	High	Risk	High	Weakness	Missing or weak authentication	Mitigation	Role-based authentication and password policy	Mitigation-ID	M-001	Risk strategy	Reduce predefined	Risk	High	Exposure Level	Medium	Exploitability	Low	Likelihood	Low	Severity	High	Risk after mitigation	Medium
------	--------	-----------	-------	----------	-------	------------	--------------------	-------------	---	--------	---------------------	--------------------	--	-----------------	----------------------------	------------------------	-----	-----------	--	--------	----------------	------	----------------	--------	------------	-----------------	------	--------	------	------	------	----------	--------------------------------	------------	---	---------------	-------	---------------	-------------------	------	------	----------------	--------	----------------	-----	------------	-----	----------	------	-----------------------	--------

Beispiel 2: Firmware Manipulation

Feld	Inhalt	Threat ID	T-002	Asset ID	A-002	Asset Name	Firmware	Description	COM, SCPU, Bootloader and NetX90 firmware	Threat	Firmware Manipulation	Threat description	Modified firmware is uploaded and executed
------	--------	-----------	-------	----------	-------	------------	----------	-------------	---	--------	-----------------------	--------------------	--

Protection Goal Integrity, Authenticity Attacker / Skill-Level Medium Rationale Firmware update mechanism accessible via IoTCore predefined likelihood Medium Exposure Level High Exploitability Medium Likelihood based on Matrix High Impact Very High Risk Critical Weakness Missing firmware signature validation Mitigation Digital signature verification Mitigation-ID M-002 Risk strategy Reduce predefined Risk Critical Exposure Level Medium Exploitability Low Likelihood Low Severity Very High Risk after mitigation Medium Beispiel 3: REST API Parameter Manipulation Feld InhaltThreat ID T-003 Asset ID A-001 Asset Name Configuration Data Description Device configuration accessible through REST API Threat Request Manipulation Threat description Manipulated API requests modify configuration values Protection Goal Integrity Attacker / Skill-Level Low Rationale REST API exposed over Ethernet predefined likelihood High Exposure Level High Exploitability High Likelihood based on Matrix High Impact High Risk High Weakness Missing input validation Mitigation Server-side validation and authorization checks Mitigation-ID M-003 Risk strategy Reduce predefined Risk High Exposure Level Medium Exploitability Low Likelihood Low Severity High Risk after mitigation Medium Beispiel 4: Replay Attack auf PROFINET / PROFIsafe Feld InhaltThreat ID T-004 Asset ID A-004 Asset Name Process Data Description

Threat Functional TestUnauthorized Access Zugriff ohne gültige Anmeldung prüfen Request Manipulation Manipulierte API Requests senden Brute Force Mehrfache Logins testen Firmware Manipulation Modifizierte Firmware hochladen Replay Attack Aufgezeichnete Telegramme erneut senden Unauthorized Configuration Change Konfiguration ohne Berechtigung ändern DoS Hohe Anzahl Requests senden Session Hijacking Session Token wiederverwenden

- **Safety zone** — Safety CPU1 (SCPU1), Safety CPU2 (SCPU2), their EEPROMs, Safe uCOS-II OS, Safe State Logic, PROFIsafe F-Parameters, Own Safe Address Storage, iPar CRC Value, F-DI/F-DO channels, Hardware Watchdog. Highest integrity/availability requirement; safety-impact relevant. - **Non-safe host zone** — Host CPU3 (COM/VHIP3), its EEPROM/flash, IoT-Core Web Interface, eRPC, bootloaders, firmware transfer/install services, error log, device tag. - **External OT zone** (conduit-connected) — the PLC/engineering network reached via PROFINET Fieldbus Ports, NetX90, DCP Protocol Service, GSD/GSDML distribution. - **External IT zone** (conduit-connected) — remote/maintenance clients reached via the IoT-Core Web Interface (HTTP), used for diagnostics and firmware management. - **Physical/production zone** — rotary switch, LEDs, debug interfaces, power/FE paths, production-mode state; requires physical access.

5. Summary and Outlook

5.1. Summary of Findings

5.2. Future Work

Bibliography

Printed Sources

- [1] K. Peffers, T. Tuunanen, M. Rothenberger, and S. Chatterjee, "A design science research methodology for information systems research," *Journal of Management Information Systems*, vol. 24, pp. 45–77, 01/2007 (cit. on pp. 1, 26).
- [2] *Sicherheit von maschinen - schutz vor korruption*, Deutsche und Englische Fassung prEN 50742:2025, Norm-Entwurf, CENELEC, 2025 (cit. on pp. 3, 10 sq., 16).
- [3] H. Gsell and A. Rajchowski, in *Software-Technologien und IT-Systeme für die Wohnungs- und Immobilienwirtschaft: Künstliche Intelligenz, Digitale Plattformen, Property Technologies, IT-Ökosysteme*. Wiesbaden: Springer Fachmedien Wiesbaden, 2026, ISBN: 978-3-658-51129-6. [Online]. Available: https://doi.org/10.1007/978-3-658-51129-6_4 (cit. on p. 4).
- [7] P. K. Garimella, "It-ot integration challenges in utilities," in *2018 IEEE 3rd International Conference on Computing, Communication and Security (ICCCS)*, 2018, pp. 199–204. DOI: 10.1109/CCCS.2018.8586807 (cit. on pp. 5 sq.).
- [8] J. Hicking, M.-F. Stroh, and S. Kremer, in *Smart and Sustainable Collaborative Networks 4.0*, L. M. Camarinha-Matos, X. Boucher, and H. Afsarmanesh, Eds., Cham: Springer International Publishing, 2021 (cit. on pp. 5, 19).
- [10] S. Liebl, L. Lathrop, U. Raithel, A. Aßmuth, I. Ferguson, and M. Söllner, "Analyzing the attack surface and threats of industrial internet of things devices," 2024. arXiv: 2405.16318 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2405.16318> (cit. on pp. 7 sq., 16).
- [11] C. Poppe, "Neue eu-maschinenverordnung: Von der richtlinie zur verordnung," *CIT-plus*, vol. 28, no. 10, pp. 32–35, 2025. [Online]. Available: <https://onlinelibrary.wiley.com/doi/abs/10.1002/citp.202501012> (cit. on p. 8).

- [12] Europäisches Parlament and Rat der Europäischen Union, *Verordnung (eu) 2023/1230 des europäischen parlaments und des rates vom 14. juni 2023 über maschinen und zur aufhebung der richtlinie 2006/42/eg des europäischen parlaments und des rates sowie der richtlinie 73/361/ewg des rates*, 06/14/2023. Accessed: Jul. 8, 2026. [Online]. Available: <https://eur-lex.europa.eu/legal-content/DE/TXT/?uri=CELEX:32023R1230> (cit. on pp. 8 sq.).
- [14] *IEC 62443-3-3:2013, Industrielle Kommunikationsnetze - IT-Sicherheit für Netze und Systeme - Teil 3-3: Systemanforderungen zur IT-Sicherheit und Security-Level*, International Electrotechnical Commission, 2019 (cit. on pp. 11 sq., 15 sq.).
- [15] *DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10: IT-Sicherheit für industrielle Automatisierungssysteme - Teil 4-1: Anforderungen an den Lebenszyklus für eine sichere Produktentwicklung*, Deutsches Institut für Normung e. V. / VDE, 10/2018 (cit. on pp. 12 sq.).
- [16] *IEC 62443-4-2:2019, IT-Sicherheit für industrielle Automatisierungssysteme - Teil 4-2: Technische Sicherheitsanforderungen an Komponenten industrieller Automatisierungssysteme (IACS)*, International Electrotechnical Commission, 2019 (cit. on p. 14).
- [18] D. Vasović, G. Janačković, Ž. Vranjanac, S. Stamenković, and B. Vasović, “Enhancing cia triad—confidentiality, integrity and availability in educational information systems through next-generation iso/iec 27001:2022-aligned security model,” *Applied Sciences*, vol. 16, no. 12, 2026. [Online]. Available: <https://www.mdpi.com/2076-3417/16/12/6260> (cit. on pp. 14 sq.).
- [19] A. Khanna, “Introduction to cybersecurity,” in *Securing an Enterprise : Maximizing Digital Experiences through Enhanced Security Measures*. Berkeley, CA: Apress, 2024, pp. 3–18. [Online]. Available: https://doi.org/10.1007/979-8-8688-1029-9_1 (cit. on pp. 14 sq.).
- [20] R. do Carmo and A. Schlensog, “Threat analysis and risk assessment,” in *Automotive Threat Analysis and Risk Assessment in Practice: A practical guide to TARA following the ISO/SAE 21434 standard for automotive embedded and IT/OT systems*. Berlin, Heidelberg: Springer Berlin Heidelberg, 2025, pp. 37–51. [Online]. Available: https://doi.org/10.1007/978-3-662-69614-9_4 (cit. on pp. 15, 17–22).
- [25] O. B. Tauqeer, S. Jan, A. O. Khadidos, A. O. Khadidos, F. Q. Khan, and S. Khattak, “Analysis of security testing techniques,” *Intelligent Automation & Soft Computing*, vol. 29, no. 1, pp. 291–306, 2021. [Online]. Available: <https://pdfs.semanticscholar.org/2aa1/9e333637ff153803c4fbd42fdad937e895e.pdf> (cit. on pp. 22 sq., 25).
- [26] B. Potter and G. McGraw, “Software security testing,” *IEEE Security & Privacy*, vol. 2, no. 5, pp. 81–85, 2004. DOI: 10.1109/MSP.2004.84 (cit. on p. 22).

- [27] J.-L. Richier, "Security testing techniques," Technical report, DIAMONDS Consortium, 2011. Deliverable ID, Tech. Rep., 2011 (cit. on pp. 22–25, 30).
- [28] N. T. Cong, L. Toan, and T. Minh, "An overview of static and dynamic analysis in application security testing," *Journal of Military Science and Technology*, vol. 99, no. 99, pp. 1–11, 2024 (cit. on pp. 23 sqq.).
- [30] K. Scarfone, M. Souppaya, A. Cody, and A. Orebaugh, "Technical guide to information security testing and assessment," National Institute of Standards and Technology, NIST Special Publication 800-115, 09/2008. Accessed: Jul. 21, 2026. [Online]. Available: <https://csrc.nist.gov/pubs/sp/800/115/final> (cit. on pp. 24 sq.).

Online Sources

- [4] "Gateway," Elektronik-Kompendium, Accessed: Jul. 16, 2026. [Online]. Available: <https://www.elektronik-kompendium.de/sites/net/0901111.htm> (cit. on p. 4).
- [5] "Layers of osi model," GeeksforGeeks, Accessed: Jul. 16, 2026. [Online]. Available: <https://www.geeksforgeeks.org/computer-networks/open-systems-interconnection-model-osi/> (cit. on p. 4).
- [6] J. Hohn. "Gateway: Definition + alles wissenswerte für 2026," Placetel, Accessed: Jul. 16, 2026. [Online]. Available: <https://www.placetel.de/ratgeber/gateway> (cit. on p. 4).
- [9] "Operational technology (ot): Definition, architektur & praxis," HWI IT, Accessed: Jul. 16, 2026. [Online]. Available: <https://hwi-it.de/blog/operational-technology-ot-grundlagen/> (cit. on pp. 5 sqq.).
- [13] M. Carl. "Neue eu-maschinenverordnung gilt ab 2027: Übergang langfristig vorbereiten," IHK Lippe zu Detmold, Accessed: Jul. 14, 2026. [Online]. Available: <https://www.ihk.de/lippe-detmold/hauptnavigation/beraten-und-informieren/innovation-und-digitalisierung/aktuelles2/neue-eu-maschinenverordnung-5683128> (cit. on p. 9).
- [17] EICTA Content Team. "What are the three goals of cybersecurity? the cia triad explained (2026)," Accessed: Jul. 19, 2026. [Online]. Available: <https://www.eicta.itk.ac.in/knowledge-hub/cyber-security/three-goals-of-cybersecurity-cia-triad> (cit. on pp. 14 sq.).
- [21] A. Gomstyn and A. Jonker. "Was ist ein angriffsvektor?" IBM Think, Accessed: Jul. 19, 2026. [Online]. Available: <https://www.ibm.com/de-de/think/topics/attack-vector> (cit. on p. 17).

- [22] "Was ist tara (threat analysis and risk assessment)?" microTOOL GmbH, Accessed: Jul. 20, 2026. [Online]. Available: <https://www.microtool.de/wissen-online/tara/> (cit. on pp. 17 sq.).
- [23] "Microsoft threat modeling tool threats, Stride model," Microsoft Learn, Accessed: Jul. 20, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats> (cit. on pp. 18 sq.).
- [24] L. Conklin. "Threat modeling process (historical)," OWASP Foundation, Accessed: Jul. 20, 2026. [Online]. Available: https://owasp.org/www-community/Threat_Modeling_Process (cit. on pp. 18 sq., 21).
- [29] "Security testing - software testing," GeeksforGeeks, Accessed: Jul. 21, 2026. [Online]. Available: <https://www.geeksforgeeks.org/software-testing/security-testing/> (cit. on pp. 23 sq.).

List of Figures

List of Tables

2.1. Comparison of Core Characteristics and Requirements in IT and OT Environments [7, p. 1] [9]	6
2.2. Mapping of STRIDE Threat Categories to Violated Cybersecurity Properties [20, p. 144] [24]	19
2.3. Technical Mitigation Techniques Mapped to STRIDE Threat Categories [24]	21
2.4. Comparison of Static Analysis Detection Approaches [28, p. 3, 8]	24
3.1. Summary of Derived Security Requirement Categories	29
4.1. Foundational Requirements and Relevant Gateway Assets	37
4.2. Threats identified for the IoTCore web interface	38
4.3. Threats identified for the REST API	38
4.4. Threats identified for firmware updates	39
4.5. Threats identified for PROFINET communication	39
4.6. Threats identified for PROFI-safe communication	40
4.7. Threats identified for persistent storage	40
4.8. Threats identified for the debug interface	40
4.9. Threats identified for engineering assets	41
A.1. List of artificial intelligence based tools used	51
B.1. Security Requirements Derived from Regulation (EU) 2023/1230	52
B.2. Mapping of MVO Security Requirements to prEN 50742	58
B.3. Mapping of MVO-derived security requirements via prEN 50742 and the IEC 62443 Foundational Requirements to IEC 62443-4-2 component requirements	60

A. Note on the Use of Artificial Intelligence

Within the scope of this thesis, tools based on Artificial Intelligence (AI) were used. Table A.1 provides an overview of the tools used and their respective purpose of application.

Table A.1.: List of AI-based tools used

Tool	Description of Use
ChatGPT	• Basic research on established principles of optical sensing for distance measurement (see Section ...) • Search for manufacturers of LiDAR sensors (see Section ...) • ...
ChatPDF	• Research and summarization of scientific studies in the field of ... • ...
DeepL	• Translation of the paper by [...]
Tabnine AI coding assistant	• Active plugin in MS Visual Studio for programming the ... • ...
...	• ...

B. Detailed Requirement Derivation Matrices

This appendix provides the complete, requirement-by-requirement documentation underlying the derivation methodology described in Section 3.1. It contains the 14 security requirements derived from Annex III, Sections 1.1.9 and 1.2.1 of **Regulation (EU) 2023/1230**, together with their detailed mapping to **prEN 50742** and, subsequently, to **IEC 62443-4-2** Component Requirements (CRs), Requirement Enhancements (REs), and component-type-specific instantiations such as Embedded Device Requirements (EDRs). The three tables correspond to the three derivation stages and share a common requirement identifier (RQ-XXX) to preserve traceability across all stages.

B.1. Security Requirements Derived from Regulation (EU) 2023/1230

Table B.1 lists the 14 requirements derived from Annex III, Sections 1.1.9 and 1.2.1 of Regulation (EU) 2023/1230. Each entry records the originating source clause, the requirement statement, the assigned Security Objective, the Requirement Type, and a rationale explaining the derivation from the regulatory text.

Table B.1.: Security Requirements Derived from Regulation (EU) 2023/1230

Field	Description
Requirement RQ-001	
Source	Annex III, Section 1.1.9
Requirement	The system shall be designed so that the connection of another device, including any remote device that communicates with it, does not lead to a hazardous situation.
Security Objective	Integrity

Table B.1 continued from previous page

Field	Description
Requirement Type	Secure Communication
Rationale	The regulatory text directly requires that any connection made by an external or remote device shall not compromise the safety of the machinery, which is a foundational requirement for secure interfacing.
Requirement RQ-002	
Source	Annex III, Section 1.1.9
Requirement	The system shall protect hardware components transmitting signal or data relevant to connection or access to safety-critical software against corruption, whether accidental or intentional.
Security Objective	Integrity
Requirement Type	Data Integrity
Rationale	The regulation requires adequate protection of safety-relevant hardware transmission paths against corruption irrespective of whether the cause is accidental or a deliberate third-party action; both causes are combined into a single verifiable protection property.
Requirement RQ-003	
Source	Annex III, Section 1.1.9
Requirement	The system shall collect evidence of any legitimate or illegitimate intervention in hardware components relevant for connection or access to safety-critical software.
Security Objective	Accountability
Requirement Type	Logging and Auditability
Rationale	The regulation mandates tamper-evidence for safety-relevant hardware, which is a direct accountability and forensic-traceability requirement.
Requirement RQ-004	
Source	Annex III, Section 1.1.9

Table B.1 continued from previous page

Field	Description
Requirement	The system shall identify the software and data that are critical for compliance with the essential health and safety requirements.
Security Objective	Integrity
Requirement Type	Configuration Protection
Rationale	The identification obligation is separated from the protection obligation contained in the same sentence, since each represents an independently verifiable engineering activity.
Requirement RQ-005	
Source	Annex III, Section 1.1.9
Requirement	The system shall protect identified safety-critical software and data against corruption, whether accidental or intentional.
Security Objective	Integrity
Requirement Type	Data Integrity
Rationale	Protection against corruption of safety-critical software and data is a single verifiable integrity property covering both accidental and deliberate causes named in the regulation.
Requirement RQ-006	
Source	Annex III, Section 1.1.9
Requirement	The system shall identify the software installed on it that is necessary for safe operation.
Security Objective	Integrity
Requirement Type	Configuration Protection
Rationale	This decomposes the identification obligation from the provisioning-of-information obligation of the same sentence, keeping one verifiable capability per requirement.
Requirement RQ-007	
Source	Annex III, Section 1.1.9

Table B.1 continued from previous page

Field	Description
Requirement	The system shall be able to provide the identification information of safety-relevant installed software at all times in an easily accessible form.
Security Objective	Availability
Requirement Type	Configuration Protection
Rationale	The requirement to make identification information accessible at all times is an independent, separately testable obligation on availability of configuration data.
Requirement RQ-008	
Source	Annex III, Section 1.1.9
Requirement	The system shall collect evidence of any legitimate or illegitimate intervention in the software installed on it.
Security Objective	Accountability
Requirement Type	Logging and Auditability
Rationale	The obligation to collect evidence of interventions in software is separated from the obligation to collect evidence of modifications to software or configuration, as intervention and modification are distinct event classes.
Requirement RQ-009	
Source	Annex III, Section 1.1.9
Requirement	The system shall collect evidence of any modification of the installed software or its configuration.
Security Objective	Accountability
Requirement Type	Logging and Auditability
Rationale	Modification of software or configuration is a distinct event class from mere intervention, and each requires an independent, verifiable evidence-collection capability.
Requirement RQ-010	
Source	Annex III, Section 1.2.1

Table B.1 continued from previous page

Field	Description
Requirement	The control system shall withstand reasonably foreseeable malicious attempts from third parties that could lead to a hazardous situation.
Security Objective	Availability
Requirement Type	Availability / Resilience
Rationale	The regulatory text explicitly names malicious third-party attempts as a factor that control systems must withstand, which is an explicit cybersecurity aspect within a broader functional-safety requirement.
Requirement RQ-011	
Source	Annex III, Section 1.2.1
Requirement	The system shall prevent modifications to safety-relevant settings or rules, including those generated during a learning phase, where such modifications could lead to a hazardous situation.
Security Objective	Integrity
Requirement Type	Configuration Protection
Rationale	The prohibition against unauthorized modification of safety-relevant settings or rules is a direct configuration-integrity protection requirement.
Requirement RQ-012	
Source	Annex III, Section 1.2.1
Requirement	The system shall enable a tracing log of data generated in relation to an intervention for five years after the machinery or related product has been placed on the market or put into service.
Security Objective	Accountability
Requirement Type	Logging and Auditability
Rationale	This requirement isolates the intervention-data logging obligation and its five-year enablement period as a single, independently verifiable capability.

Table B.1 continued from previous page

Field	Description
Requirement RQ-013	
Source	Annex III, Section 1.2.1
Requirement	The system shall enable a tracing log of the versions of safety software uploaded after the machinery or related product has been placed on the market or put into service, for five years after each upload.
Security Objective	Accountability
Requirement Type	Logging and Auditability
Rationale	Logging of safety software versions is separated from logging of intervention data because it concerns a distinct data object with its own retention trigger.
Requirement RQ-014	
Source	Annex III, Section 1.2.1
Requirement	The system shall restrict access to the tracing log data exclusively to demonstrating conformity further to a reasoned request from a competent national authority.
Security Objective	Confidentiality
Requirement Type	Access Control
Rationale	The regulation constrains the purpose for which the logged data may be accessed, which is a distinct access-control obligation separate from the logging and retention obligations.

B.2. Mapping to prEN 50742

Table B.2 maps the 14 requirements of Table B.1 onto the corresponding clauses of **prEN 50742** (*Safety of machinery - Protection against corruption*). The mapping covers Approach A (Sections 4, 5, 7) and Annex ZZ, which are the only parts of the source text providing clause-level content. Approach B (Sections 6, 8) is referenced only where it explicitly names a target standard or clause (e.g. **CR 2.8**); CR and SR numbers not present in the source text are not inferred.

Table B.2.: Mapping of MVO Security Requirements to prEN 50742

MVO ID	prEN 50742 Clause	prEN 50742 Requirement/Topic	Mapping Type
RQ-001	§4.2	Design/construction of machinery shall not permit hazardous situations arising from connections (physical, logical, indirect).	Direct
RQ-002	§1; §7.1; §7.2.1	Scope explicitly includes hardware components/interfaces (incl. remote-device interfaces) that transmit signals/data affecting machine safety; §7.1 requires identification and protection of accessible interfaces by compensating/countermeasures.	Partial
RQ-003	§3.4; §7.3.3	“Evidence” definition includes physical tamper evidence (broken seals, damaged interface covers, e.g. RJ45); §7.3.3 requires physical evidence where digital evidence collection is not reasonably practicable.	Partial
RQ-004	§3.12; §7.5; §7.4.1	“Critical data” defined as data whose manipulation can increase hazard; §7.5 requires identification of software versions/configuration data relevant for protection against falsification.	Partial
RQ-005	§7.4.3.4.1	SRSL-graded software/information integrity requirements, from checksum verification at start-up (SRSL1) to cryptographic hash/HMAC/CMAC verification during operation (SRSL3).	Direct
RQ-006	§7.5	Identification of software versions/configuration data “relevant for protection against falsification” must be available.	Partial
RQ-007	§7.5	Identification data “must be available on request”, in readable form, via an integrated system or an external tool.	Partial
RQ-008	§3.2; §7.3.1; §7.3.2; §7.3.3	Enumerated intervention types (safety parametrization, SRESW/SRASW update, HMI parametrization, safety-instruction display software) with minimum recorded data (type, correlation means, log-deletion event).	Direct

Table B.2 continued from previous page

MVO ID	prEN 50742 Clause	prEN 50742 Requirement/Topic	Mapping Type
RQ-009	§3.2; §3.3; §7.3.1; §7.3.2	“Modification” is defined as a change caused by an “intervention”, incl. software version, sensor calibration, configuration data); §7.3.1 b)/c) require identification means (version number, CRC) for SRESW/SRASW updates.	Direct
RQ-010	§4.3; Introduction	Process principles: eliminate vulnerabilities that could lead to hazardous situations; otherwise mitigate; otherwise inform the user via user information of compensating measures (Annex C).	Partial
RQ-011	§7.4.3.3.1; §3.2	SRSL-graded authorization requirements for interventions (SRSL1/2: authorization required; SRSL3: privileged/role-based authorization); the “intervention” definition names safety routines, safety variables, and calibration data as examples.	Partial
RQ-012	§7.3.4	Log must contain at least the evidence of the last intervention of each type; records retained at least five years; log active at the latest from the time the machinery is put into service.	Direct
RQ-013	§7.3.1	Explicit exclusion: versions of SRASW/SRESW binaries need not be stored in the tracing log.	Not identified
RQ-014	§7.3.5; §7.3.3	Logs must be “properly secured” against tampering; deletion only via an authorized procedure; digital evidence must be readable and accessible.	Partial

B.3. Mapping to IEC 62443-4-2

Table B.3 extends the derivation chain from **prEN 50742** to IEC 62443-4-2. Where no **prEN 50742** clause is available, the mapping proceeds directly from **Regulation (EU) 2023/1230**. IEC 62443-4-2 organizes its Component Requirements under the seven Foundational Requirements introduced in Section 2.2.3.

Table B.3.: Mapping of MVO-derived security requirements via prEN 50742 and the IEC 62443 Foundational Requirements to IEC 62443-4-2 component requirements

MVO ID	FR	CR/RE/EDR	IEC 62443-4-2 Topic	Mapping Rationale	Type
RQ-001	FR3	CR 3.1	Communication integrity	prEN §4.2 requires that physical, logical, and indirect connections not create hazardous situations; CR 3.1 requires the component to verify the integrity of information transmitted over a communication channel, the closest component-level control for connection-related corruption.	Partial
RQ-002	FR2; FR3	CR 3.1; CR 2.13	Communication integrity; Use of physical diagnostic/test interfaces	prEN §7.1 requires identification and protection of accessible interfaces (incl. remote-device interfaces) by compensating/countermeasures: CR 3.1 covers the integrity of transmitted information itself; CR 2.13 covers control of physical diagnostic/test interfaces, the interface class prEN singles out (e.g. RJ45, §3.4).	Partial
RQ-003	FR2; FR3	CR 2.8; CR 2.12; CR 2.13; CR 3.11	Auditable events; Non-repudiation; Use of physical diagnostic/test interfaces; Physical tamper resistance and detection	prEN §7.3.3 makes physical evidence (CR 3.11) the fallback used only where digital evidence collection (CR 2.8) is not practicable. CR 2.8 supplies the primary digital-evidence/event-generation mechanism; CR 2.12 supplies the attribution property implied by “legitimate or illegitimate” (the evidence must be undeniably traceable to the causing action); CR 2.13 matches prEN’s own physical diagnostic/test-interface example (RJ45 cover, §3.4).	Direct

B. Detailed Requirement Derivation Matrices

Table B.3 continued from previous page

MVO ID	FR	CR/RE/EDR	IEC 62443-4-2 Topic	Mapping Rationale	Type
RQ-004	FR7	CR 7.8	Control system component inventory	prEN's "critical data" definition and §7.5 require identification of software versions/configuration data relevant to falsification protection; CR 7.8's component-inventory capability is the closest CR-level asset-identification control.	Partial
RQ-005	FR3	CR 3.4; EDR 3.14	Software and information integrity; Integrity of the boot process (embedded device)	prEN's SSSL-graded integrity framework (§7.4.3.4) covers general software/information integrity (§7.4.3.4.1 → CR 3.4) and, as a distinct sub-case, boot-process integrity (§7.4.3.4.2). Since prEN 50742's machinery controllers are typically embedded devices, the embedded-device-specific EDR 3.14 applies rather than the generic base CR 3.14.	Direct
RQ-006	FR7	CR 7.8	Control system component inventory	Same underlying identification obligation as RQ-004 and RQ-007; CR 7.8's inventory capability is the closest CR-level match for tracking installed-software identity.	Partial
RQ-007	FR7	CR 7.8	Control system component inventory	prEN requires availability "on request" rather than "at all times"; CR 7.8 supports retrieval of inventory information but does not mandate continuous, unsolicited availability, so the mapping only partially closes the MVO obligation.	Partial

B. Detailed Requirement Derivation Matrices

Table B.3 continued from previous page

MVO ID	FR	CR/RE/EDR	IEC 62443-4-2 Topic	Mapping Rationale	Type
RQ-008	FR2; FR3	CR 2.8; CR 2.12; CR 3.4	Auditable events; Non-repudiation; Software and information integrity	prEN §8.5 anchors the enumerated intervention types and minimum recorded data to CR 2.8 (event generation); the “legitimate or illegitimate” attribution qualifier matches CR 2.12 (non-repudiation).	Direct
RQ-009	FR2; FR3	CR 2.8; CR 2.12; CR 3.4	Auditable events; Software and information integrity; Non-repudiation	prEN’s “modification” definition and the version-number/CRC identification means in §7.3.1 b)/c) combine an audit obligation (CR 2.8) with an integrity-verification obligation (CR 3.4); CR 2.12 is added for consistency with RQ-003 and RQ-008 since modification evidence is likewise subject to the attribution qualifier.	Direct
RQ-010	-	-	-	This is a process-level risk-treatment principle rather than a technical component capability; IEC 62443-4-2 defines component-technical CRs and assigns such process obligations to IEC 62443-4-1. No corresponding CR exists.	No direct mapping
RQ-011	FR1; FR2	CR 1.1; CR 2.1	Human user identification and authentication; Authorization enforcement	prEN’s SRSI-graded authorization requirement for “interventions” corresponds to CR 2.1; CR 1.1 is added because §7.4.3.2.1’s entity-authentication precondition must be satisfied before CR 2.1’s authorization enforcement is meaningful. The learning-phase aspect has no counterpart in either prEN or IEC 62443-4-2.	Partial

B. Detailed Requirement Derivation Matrices

Table B.3 continued from previous page

MVO ID	FR	CR/RE/EDR	IEC 62443-4-2 Topic	Mapping Rationale	Type
RQ-012	FR2	CR 2.8; CR 2.9	Auditable events; Audit storage capacity	prEN's requirement that the log retain at least the evidence of the last intervention of each type, kept for five years, combines the event-generation obligation of CR 2.8 with the storage-capacity obligation of CR 2.9.	Direct
RQ-013	FR2	CR 2.8 (conflict); CR 2.9	Auditable events	prEN explicitly excludes SRASW/SRESW binary versions from the tracing log, which conflicts with the MVO's software-version-upload-logging requirement. This is a confirmed conflict rather than a supporting mapping.	No direct mapping
RQ-014	FR3; FR6	CR 3.9; CR 6.1	Protection of audit information; Audit log accessibility	prEN requires logs to be secured against tampering, with deletion only via an authorized procedure (CR 3.9); §7.3.3 requires that digital evidence be readable and accessible (CR 6.1). The MVO's additional purpose-restriction (access exclusively for conformity demonstration) is not reflected in either source.	Partial